

merci-audit:silence-style

La Vida Oculta detrás de las Comunicaciones Seguras con PGP

Art de Côté | Cuadernillo

En el núcleo estático de mercedev.es, encontramos un desafío: cómo permitir a clientes y auditores enviar información confidencial sin comprometer la integridad de nuestra arquitectura estática. Los formularios tradicionales, basados en PHP o Node.js, son complejos y llenos de posibles vulnerabilidades. Además, los correos electrónicos no cifrados pueden ser interceptados por cualquier nodo intermedio.

La solución que encontrada es implementar un modelo de comunicación asimétrica utilizando el estándar PGP (Pretty Good Privacy) mediante la herramienta nativa GnuPG. Esta elección permite generar un par de claves criptográficas locales, protegiendo la clave privada con una frase de paso fuerte.

En lugar de desplegar una API REST para procesar mensajes, se exporta la clave pública a un archivo ASCII de texto plano y se deposita en el directorio `/public/` para que sea servido directamente desde el servidor web como un activo estático. En la página de contacto, se publica el enlace al archivo `.asc` junto con la Huella Digital criptográfica.



Resumiendo:

En lugar de formularios de contacto vulnerables y dependientes de backend, se ha optado por una solución más segura: ofrecer una "caja fuerte" pública. Cualquiera puede descargarse nuestra "llave pública" para cifrar un mensaje desde su propio ordenador. Ese mensaje viaja por internet como un código indescifrable que nadie puede leer, y solo nosotros podemos abrirlo al recibirlo.

Para saber más sobre cómo se implementó esta solución, puedes leer el [cuadernillo completo](#).